

Seguridad con Jakarta EE



Guía Paso a Paso: Agregando Seguridad en el Proyecto SGA-JEE-WEB con Jakarta EE

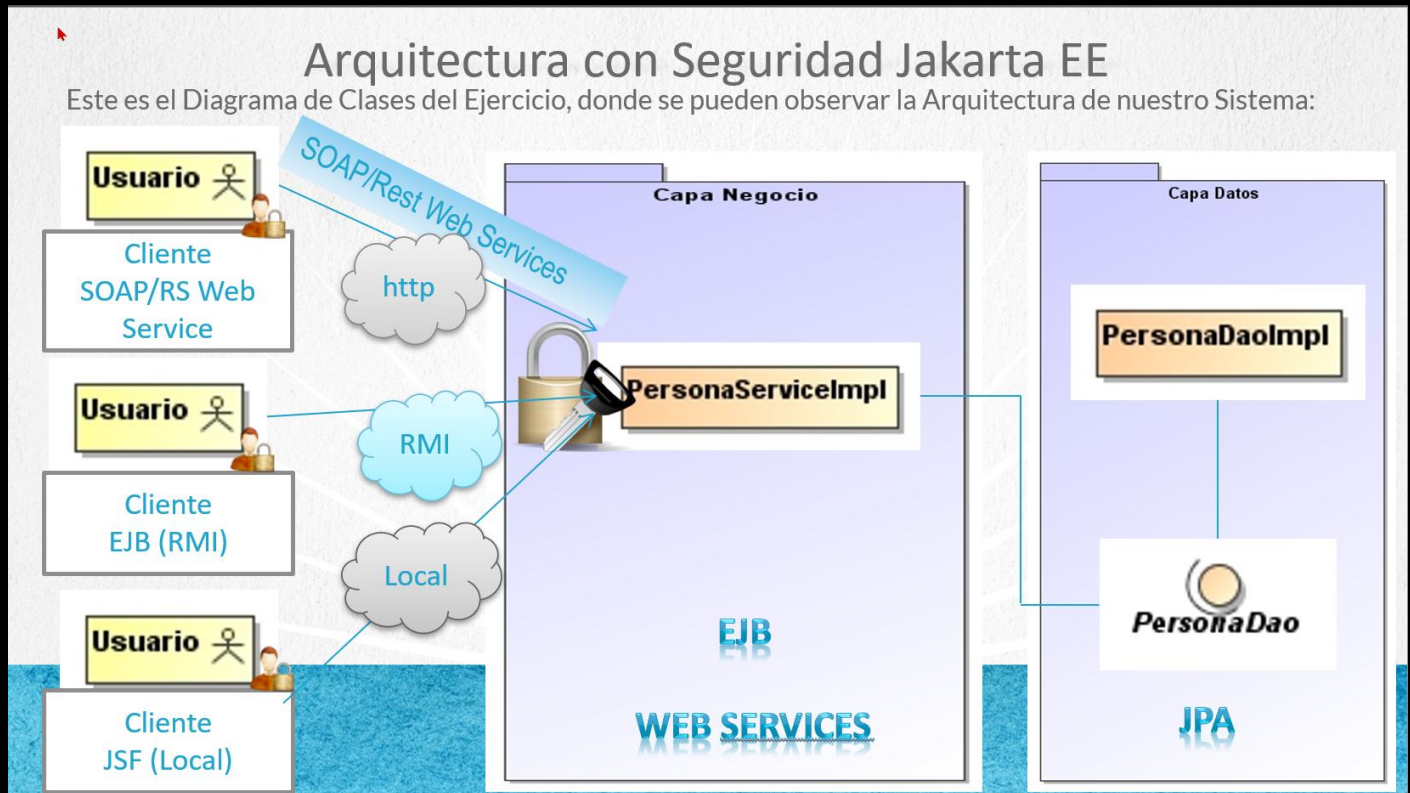
Introducción

En esta lección aprenderemos cómo proteger nuestros servicios empresariales en el sistema **SGA-JEE-WEB**

. Implementaremos **seguridad declarativa** para evitar que cualquier cliente (Web, SOAP o REST) acceda directamente a nuestros servicios sin antes autenticarse.

También aprenderás a restringir qué usuarios pueden ejecutar ciertos métodos como eliminar registros, ¡una capa más de control para tu sistema! 

Arquitectura con Seguridad en Jakarta EE:



Paso 1: Crear una copia del proyecto actual

1. Cerramos los proyectos anteriores que ya no utilizemos dando clic derecho → Close.
2. Trabajaremos de momento en el proyecto **sga-jee-web**.



Paso 2: Detener GlassFish si está activo

Antes de continuar, asegurémonos de que el servidor **GlassFish** esté detenido:

- Clic derecho sobre el servidor GlassFish → Stop.



Paso 3: Agregar restricciones al servicio EJB

Vamos a proteger el archivo:

`src/main/java/sga/servicio/PersonaServiceImpl.java`

<https://www.globalmentoring.com.mx>

Modificamos el servicio con anotaciones de seguridad

1. Arriba de la clase `PersonaServiceImpl`, agregamos:

```
@DeclareRoles({"ROLE_ADMIN", "ROLE_USER"})  
@RolesAllowed({"ROLE_ADMIN", "ROLE_USER"})
```

➡ Esto indica que solo los usuarios autenticados con esos roles podrán usar este EJB.

2. Sobre el método `eliminarPersona(Persona persona)`, agregamos:

```
@RolesAllowed("ROLE_ADMIN")
```

➡ Solo los usuarios con rol **ADMIN** podrán eliminar registros.

🔊 ¡No olvides importar las clases desde `jakarta.annotation.security`!

Paso 4: Probar que el servicio ya está protegido

1. Clic derecho sobre el proyecto `SGA-JEE-WEB` → Clean and Build 🛠
2. Luego → Run 🚀

Una vez desplegado, accedemos a:

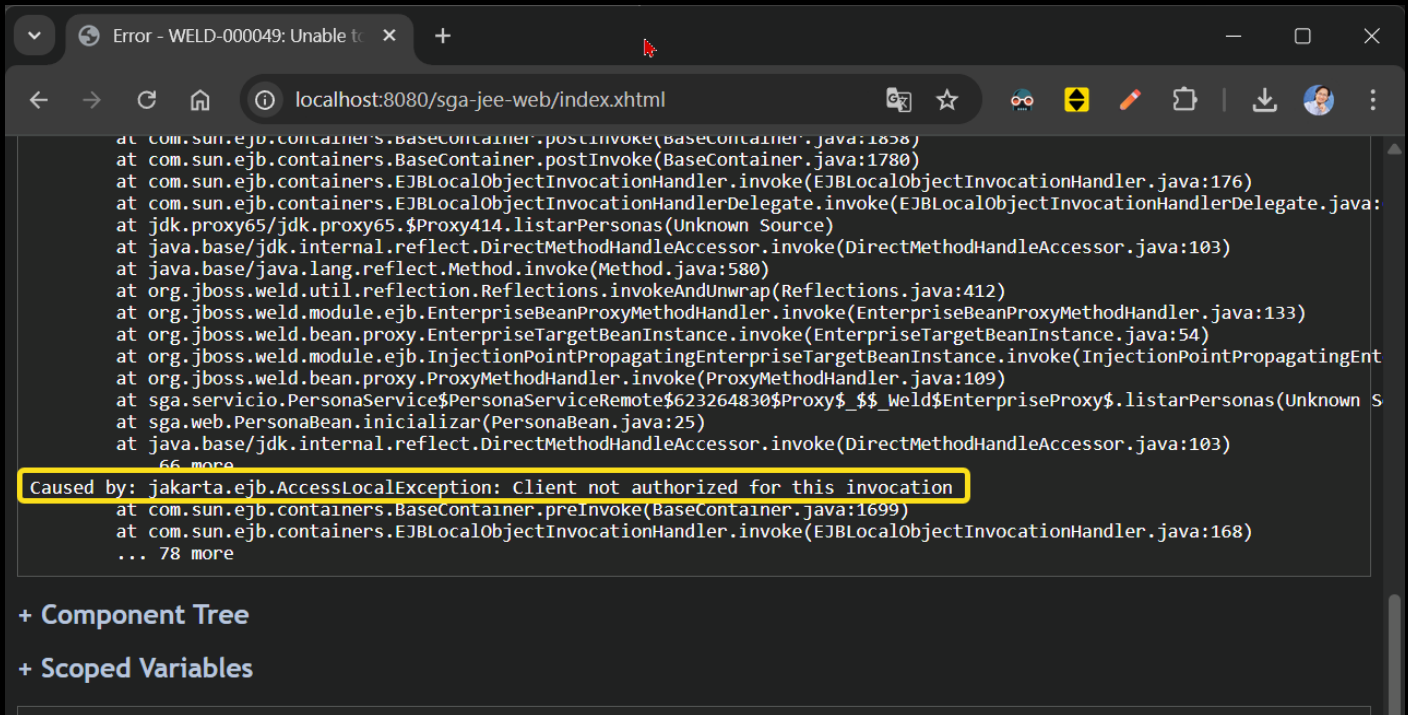
<http://localhost:8080/sga-jee-web/>

3. Haz clic en **Listar personas**.

🚫 Verás el siguiente mensaje de error:

```
WELD-000049: Unable to invoke public void sga.web.PersonaBean.inicializar() on  
sga.web.PersonaBean@76cf98ce
```

```
Caused by: jakarta.ejb.AccessLocalException: Client not authorized for this invocation
```



```
at com.sun.ejb.containers.BaseContainer.postInvoke(BaseContainer.java:1838)
at com.sun.ejb.containers.BaseContainer.postInvoke(BaseContainer.java:1780)
at com.sun.ejb.containers.EJBLocalObjectInvocationHandler.invoke(EJBLocalObjectInvocationHandler.java:176)
at com.sun.ejb.containers.EJBLocalObjectInvocationHandlerDelegate.invoke(EJBLocalObjectInvocationHandlerDelegate.java:
at jdk.proxy65/jdk.proxy65.$Proxy414.listarPersonas(Unknown Source)
at java.base/jdk.internal.reflect.DirectMethodHandleAccessor.invoke(DirectMethodHandleAccessor.java:103)
at java.base/java.lang.reflect.Method.invoke(Method.java:580)
at org.jboss.weld.util.reflection.Reflections.invokeAndUnwrap(Reflections.java:412)
at org.jboss.weld.module.ejb.EnterpriseBeanProxyMethodHandler.invoke(EnterpriseBeanProxyMethodHandler.java:133)
at org.jboss.weld.bean.proxy.EnterpriseTargetBeanInstance.invoke(EnterpriseTargetBeanInstance.java:54)
at org.jboss.weld.module.ejb.InjectionPointPropagatingEnterpriseTargetBeanInstance.invoke(InjectionPointPropagatingEnt
at org.jboss.weld.bean.proxy.ProxyMethodHandler.invoke(ProxyMethodHandler.java:109)
at sga.servicio.PersonaService$PersonaServiceRemote$623264830$Proxy$_$$_Weld$EnterpriseProxy$.listarPersonas(Unknown S
at sga.web.PersonaBean.inicializar(PersonaBean.java:25)
at java.base/jdk.internal.reflect.DirectMethodHandleAccessor.invoke(DirectMethodHandleAccessor.java:103)
... 66 more
Caused by: jakarta.ejb.AccessLocalException: Client not authorized for this invocation
at com.sun.ejb.containers.BaseContainer.preInvoke(BaseContainer.java:1699)
at com.sun.ejb.containers.EJBLocalObjectInvocationHandler.invoke(EJBLocalObjectInvocationHandler.java:168)
... 78 more
```

+ Component Tree

+ Scoped Variables

🎉 ¡Perfecto! Esto indica que nuestro servicio ahora **requiere autenticación y autorización**. Ningún cliente puede usarlo sin un usuario válido.



Conclusión

✅ En esta lección implementamos **seguridad en la capa de servicios** del sistema SGA utilizando las anotaciones:

- @DeclareRoles
- @RolesAllowed



También aprendimos a:

- **Restringir métodos específicos** como `eliminarPersona(...)` solo para administradores.
- **Proteger todo el EJB** contra accesos no autorizados desde cualquier tipo de cliente.



SOON En los siguientes videos aprenderemos a modificar los **clientes SOAP, REST y Web** para autenticar correctamente al invocar estos servicios.

Sigue adelante con tu aprendizaje 🚀, ¡el esfuerzo vale la pena!

¡Saludos! 🙌

Ing. Marcela Gamiño e Ing. Ubaldo Acosta

Fundadores de [GlobalMentoring.com.mx](https://www.globalmentoring.com.mx)